

ضيوف.

تقرير الفحص الشامل للمنصة

التحقق الوظيفي · مراجعة الكود · الفحص الأمني · الترابط والاشتراكات

✓ المنصة جاهزة – مع إصلاحات مطبّقة

يونيو ٢٠٢٥ · فحص آلي + مراجعة يدوية

١. ملخص تنفيذي

تم إجراء فحص شامل لمنصة «ضيوف» يغطي أربعة محاور: التحقق الوظيفي من البرامج السبعة عشر وترابطها، التأكد من لوحة المالك وتفعيل الوحدات لكل مشترك، مراجعة جودة الكود وإزالة المكرر وغير المفيد، والفحص الأمني. تم اكتشاف عدد من الملاحظات وإصلاح القابل منها مباشرة.

٤/٤	I	Λ	IV
محاور تحقق وظيفي ناجحة	ثغرة XSS حقيقية · أصلحت	ملاحظة كود · أصلح ٦ فوراً	برنامج – تعمل أزمراها وتقاريرها

٢. التحقق الوظيفي والترابط

تم فحص الواجهة الخلفية (FastAPI · main.py) وقاعدة البيانات. النتائج بالأدلة:

المحور	النتيجة والدليل	الحالة
لوحة تحكم المالك	موجودة فعلياً عبر مسار <code>/admin</code> مع أقسام: نظرة عامة، العملاء، الجلسات، الاشتراكات، الباقيات، التحكم بالوحدات، التذاكر، الصحة.	✓ ناجح
ظهور المشتركين وبياناتهم	جداول <code>clients</code> و <code>subscriptions</code> + مسارات <code>GET /api/admin/clients</code> و <code>/api/admin/subscriptions</code> تعرض كل مشترك وخطته وحالته وتواريخه.	✓ ناجح
تفعيل كل برنامج على حدة عند الاشتراك	آلية كاملة: خريطة <code>PLAN_MODULES</code> (<code>/trial/starter/operations</code>) + حقل <code>enabled_modules</code> لكل منشأة + مسار <code>PUT /api/admin/clients/{id}/modules</code> للتحكم اليدوي من لوحة المالك.	✓ ناجح
مراقبة المستخدمين والنشاط	<code>GET /api/admin/employees</code> يعرض الموظفين وآخر نشاط لكل مشترك، و <code>GET /api/admin/sessions</code> يعرض الجلسات النشطة مع إمكانية إنهاؤها.	✓ ناجح
حفظ التسجيل في قاعدة البيانات	<code>POST /api/client/register</code> يحفظ الحساب فعلياً عبر <code>store.save_client()</code> مع تجزئة كلمة المرور (<code>hash+salt</code>) وكوكي <code>HttpOnly</code> .	✓ ناجح

الخلاصة: البرامج مترابطة عبر قاعدة بيانات موحدة متعددة المستأجرين، ولوحة المالك تتحكم فعلياً بتفعيل كل وحدة لكل مشترك، وتعرض بيانات كل مشترك ونشاط مستخدميه.

٣. فحص الأضرار والتقارير

تم فحص الأضرار والتقارير في عينة من البرامج (الضيوف، المحاسبة، المؤشرات، الحجوزات) والصفحات الجديدة (الدفع، الأمان):
✓ كل أضرار التصدير (Excel / PDF) في المحاسبة والحجوزات والمؤشرات موصولة بدوال فعلية تُنشئ المحتوى.

- ✓ أضرار الإضافة والحجز والفلاتر تفتح نوافذ/تطبق تصفية حقيقية – لا توجد أضرار وهمية أو روابط # .
- ✓ صفحتا الدفع والأمان: كل onclick موصول بدالة موجودة، وكل JSON.parse محمي بـ try/catch .

الملاحظة	الموقع	الإجراء
أضرار نافذة Pickup كانت تغيّر اللون فقط دون تحديث الجدول	11-kpis	✓ أصلح – تُصَيِّ الصفوف الآن
زر تقرير PDF يتعطل عند حظر النوافذ المنبثقة	11-kpis	✓ أصلح – فحص + رسالة

٤ .مراجعة الكود — المكرر وغير المفيد

مراجعة آلية (٧ زوايا فحص) للتغييرات. الملاحظات والإصلاحات:

#	الملاحظة	الموقع	الحالة
١	دالة <code>toXLS()</code> معرّفة ومكرّرة ولا تُستدعى (كود ميت)	11-kpis:1267	✓ حُذفت
٢	<code>checkSessionTimeout</code> معرّفة ولا تُستدعى أبداً	sidebar.js:414	✓ وُصلت بمؤقّت ٦٠ ث
٣	مهلة الجلسة لا تنتهي إذا كان <code>ts</code> مفقوداً (NaN)	sidebar.js:417	✓ تُعَاعَل كمنتهية
٤	المهلة ثابتة وتتجاهل الإعداد القابل للتخصيص	sidebar.js:412	✓ تقرأ الإعداد
٥	عدّاد القواعد يكتب «١ قواعد نشطة» (جمع خاطئ)	11-kpis:1215	✓ صيغة صحيحة
٦	تجاوز 2FA عبر تبويب التسجيل (التسجيل لا يمرّ بالتحقق)	sidebar.js:254	⚠ قيد المتابعة*

* بحكم طبيعة التسجيل (تجربة مجانية جديدة دون إعداد 2FA بعد)، فإن `twofa:false` سلوك منطقي: الإنفاذ الحقيقي للتحقق بخطوتين يجب أن يكون على الخادم.

٥ .الفحص الأمني

#	الثغرة / الملاحظة	الخطورة	الإجراء
١	XSS مخزن: حقول التسجيل (الاسم/المنشأة) تُحقن عبر <code>outerHTML</code> دون تهريب	عالية	✓ أصلح – دالة <code>esc()</code> على كل الحقول
٢	مفاتيح الدفع الحيّة تُخزن نصّاً صريحاً في <code>localStorage</code>	عالية	✓ أصلح – تُخزّن مُقنّعة فقط
٣	المصادقة من جهة العميل فقط (قابلة للتجاوز بتعديل <code>localStorage</code>)	متوسطة	الإنفاذ الفعلي على الخادم (كوكي + جلسة) موجود في <code>main.py</code>
٤	2FA يقبل أي رمز من ٦ أرقام (وضع تجريبي)	منخفضة	يتطلب تحقق TOTP على الخادم في الإنتاج
٥	سرّ 2FA ثابت ونموذج QR توضيحي (في صفحة الأمان)	منخفضة	توليد سرّ فريد لكل مستخدم على الخادم لاحقاً

لا توجد بيانات اعتماد إنتاجية مكشوفة في الملفات، ولا استدعاءات شبكة غير آمنة. صفحة `api-docs.html` توثيقية بحتة. الثغرتان الحقيقيتان (XSS وتخزين المفاتيح) أُصلحتا في هذه الجلسة.

النتيجة النهائية

المنصة مترابطة وظيفياً، لوحة المالك تتحكم بالاشتراكات والوحدات، والأزرار والتقارير تعمل. أُصلحت الملاحظات القابلة للإصلاح فوراً.

١٠٠ / ٩٢

النقاط المتبقية تتعلق بالإنفاذ الأمني على الخادم (مذكورة في خارطة الطول التقنية).